

Vol d'Histoire

Encyclopédie web de l'aviation militaire — version v4.9.0

vol-histoire.titouan-borde.com · audit du 8 septembre 2026, correctifs du 8 septembre 2026

SCORE GLOBAL

83 → 99 / 100

Domaine	Avant	Après	Corrigés	Ouverts
1. Architecture & structure	92	100	1	1
2. HTML & sémantique	100	100	1	—
3. CSS & design system	88	100	4	1
4. JavaScript	94	100	3	—
5. Performance	82	94	5	3
6. Accessibilité	41	100	14	—
7. Sécurité	82	98	4	2
8. SEO technique	96	100	2	1
9. Conformité RGPD	69	100	5	—
10. Qualité du code	98	100	1	1
11. Mobile & PWA	98	100	1	—
12. Contenu & éditorial	98	100	2	—

Synthèse exécutive

L'audit initial du 8 septembre 2026 a porté sur l'intégralité du dépôt : 18 pages HTML, 24 feuilles de style source, 51 modules JavaScript front, l'API Express et ses 11 routes, la base de 383 fiches et la chaîne de build. Il a retenu **51 constats** et documenté **32 points conformes**. Les correctifs ont été appliqués le 8 septembre 2026 : **43 constats sont corrigés, 9 restent ouverts et 1 a été écarté** sur décision. La vérification qui a suivi a fait apparaître deux constats de plus, dont l'un est corrigé et l'autre ouvert — ils portent le total à 53.

Ce que les mesures disent

Indicateur	Avant	Après
Violations axe-core (11 pages, WCAG 2.0/2.1/2.2 AA)	1 violation, 6 nœuds	0
Lighthouse — bonnes pratiques	96	100
Lighthouse — performance	86	86
Lighthouse — accessibilité	100	100
Lighthouse — SEO	100	100
LCP (accueil, mobile émulé)	4 140 ms	4 208 ms
Total Blocking Time	92 ms	55 ms
Cumulative Layout Shift	0,005	0,000
Économies d'images potentielles	536 Kio	239 Kio
Ressources à cache court	21	10
Erreurs en console (visite anonyme)	1 (401)	0
app.min.js (chargé sur toutes les pages)	111,6 Ko	27,5 Ko
npm audit --omit=dev	10 vulnérabilités, dont 3 « high »	0
Couverture de frontend/js/utils.js	52,43 %	91,46 %
Tests backend	551	555
Tests frontend	146	162
Scénarios E2E	120 réussis / 1 échec	120 réussis / 1 échec
ESLint / html-validate	0 / 0	0 / 0

Toutes ces valeurs ont été reproduites sur le même poste, serveur local en NODE_ENV=test. Le LCP a été mesuré trois fois après correctifs : 4207, 4208 et 4208 ms — la métrique est stable, l'absence de progrès n'est pas un artefact.

Verdict

Les deux constats critiques sont fermés. La garde de consentement de Sentry lisait une clé de stockage inexistante et ne se déclenchait donc jamais : elle passe désormais par un accesseur unique `window.VH.consent`, seul détenteur du nom de la clé et de la forme stockée, pour que le décalage ne puisse pas se reproduire. Le lien d'évitement du hangar pointait vers une ancre absente : la page a retrouvé un `<main>`.

L'accessibilité est le domaine qui bouge le plus, de 41 à 100 : **axe-core ne relève plus aucune violation sur les onze pages testées**, contre une auparavant. Les dépendances de production passent de dix vulnérabilités, dont trois « high », à zéro — `npm audit fix` pour quatre d'entre elles, puis une montée de nodemailer de la version 8 à la 10, validée par les 555 tests. La couverture de `utils.js` passe de 52 à 91 %% : le seuil est tenu par des tests supplémentaires, pas en abaissant la barre.

Trois réserves, énoncées telles quelles. D'abord, le LCP n'a pas progressé : la conversion de l'image du quiz en AVIF l'a bien sortie de la position d'élément LCP, mais le retard s'est déplacé vers le rendu du titre, où il pèse 89 %% du délai — c'est le constat PERF-08, ouvert. Ensuite, le score résiduel de 99 reflète le barème, pas la perfection : il ne reste presque que des constats informatifs. Enfin, la police Orbitron a été retirée des feuilles de style parce qu'elle n'était jamais chargée ; l'afficher réellement serait un choix de design, pas un correctif.

Ce qui reste ouvert

ID	Constat	Sév.	Effort
PERF-08	Le LCP reste à 4,2 s, désormais bloqué par le rendu du titre frontend/index.html	Majeur	M
SEC-04	jwt.verify sans restriction explicite d'algorithme backend/middleware/auth.js	Mineur	S
SEC-06	firstname/lastname du formulaire de contact non validés backend/routes/contact.js	Info	S
PERF-06	430 ms de CSS bloquant le rendu sur l'accueil frontend/index.html	Info	M
PERF-07	119 Mo d'images dans le dépôt, en triple exemplaire frontend/assets/airplanes/	Info	L
SEO-03	Meta description de la chronologie au-dessus de la limite d'affichage frontend/timeline.html	Info	S
CSS-05	Approche desktop-first, contrairement au mobile-first documenté frontend/css/	Info	M
ARCH-03	Trois feuilles de style dépassent le seuil de 800 lignes du projet frontend/css/shared-base.css	Info	M
QUAL-02	Convention de guillemets non tenue dans quelques fichiers frontend/js/login.js	Info	S

Un seul constat majeur subsiste (PERF-08). Les huit autres sont mineurs ou informatifs, et n'avaient pas été retenus dans le périmètre de correction.

Sommaire

Section	Contenu
Synthèse exécutive	Mesures avant / après, verdict, ce qui reste ouvert
1. Architecture & structure	3 constat(s) · 1 corrigé(s), 1 ouvert(s) · score 92 → 100
2. HTML & sémantique	1 constat(s) · 1 corrigé(s), 0 ouvert(s) · score 100 → 100
3. CSS & design system	5 constat(s) · 4 corrigé(s), 1 ouvert(s) · score 88 → 100
4. JavaScript	3 constat(s) · 3 corrigé(s), 0 ouvert(s) · score 94 → 100
5. Performance	8 constat(s) · 5 corrigé(s), 3 ouvert(s) · score 82 → 94
6. Accessibilité	14 constat(s) · 14 corrigé(s), 0 ouvert(s) · score 41 → 100
7. Sécurité	6 constat(s) · 4 corrigé(s), 2 ouvert(s) · score 82 → 98
8. SEO technique	3 constat(s) · 2 corrigé(s), 1 ouvert(s) · score 96 → 100
9. Conformité RGPD	5 constat(s) · 5 corrigé(s), 0 ouvert(s) · score 69 → 100
10. Qualité du code	2 constat(s) · 1 corrigé(s), 1 ouvert(s) · score 98 → 100
11. Mobile & PWA	1 constat(s) · 1 corrigé(s), 0 ouvert(s) · score 98 → 100
12. Contenu & éditorial	2 constat(s) · 2 corrigé(s), 0 ouvert(s) · score 98 → 100
Plan d'action restant	Les 9 constats encore ouverts
Annexe A — Points conformes	32 contrôles passés avec succès
Annexe B — Limites de l'audit	7 sujets non testés, et pourquoi
Annexe C — Méthodologie	Commandes exécutées, outils, versions, notation

1. Architecture & structure

Score : 92 → 100/100 — 1 majeur · 1 mineur · 1 info · 1 corrigé(s), 1 ouvert(s)

MAJEUR	ARCH-01 — slugify() est dupliqué caractère pour caractère entre le SSR et utils/url.js	CORRIGÉ
Fichier	backend/routes/details-ssr.js : ligne 29-35	
Preuve	Les deux implémentations sont identiques (backend/utils/url.js:21-27 et details-ssr.js:29-35). details-ssr.js ne fait aucun require('../utils/url') — vérifié sur la liste de ses require (lignes 11-14).	
Constat	Les URL canoniques SEO des 383 fiches sont produites par une copie de la fonction, pas par la source commune. Le même algorithme est d'ailleurs réimplémenté deux fois de plus côté frontend (details/data.js:5-12 et shared/card.js:84-91).	
Impact	Une correction du slug dans utils/url.js ne se propagerait pas au SSR : divergence silencieuse entre l'URL générée et l'URL attendue, donc 404 ou duplication d'URL côté moteur.	
Correctif	Faire pointer details-ssr.js vers utils/url.js ; centraliser la version frontend dans shared/.	
Effort	S — moins d'une heure	
Appliqué	backend/routes/details-ssr.js — les copies locales de slugify() et idFromSlug() sont supprimées au profit de require('../utils/url'). Les URL canoniques des 383 fiches ont maintenant une source unique.	
MINEUR	ARCH-02 — 17 fichiers SVG de logo ne sont référencés nulle part	ÉCARTÉ
Fichier	frontend/assets/logo/ : ligne —	
Preuve	Recherche du nom de chaque fichier dans tout frontend/ et backend/ (html, js, css, json, webmanifest, hors bundles) : 17 des 24 SVG ont zéro occurrence — vh-emblem-gold, vh-icon-only-{dark,gold,paper}, vh-lockup-horizontal-{dark,gold,paper}, vh-lockup-horizontal-mono-dark, vh-lockup-stacked-{dark,gold,paper}, vh-mark-flat-{dark,gold,paper}, vh-mark-primary-{dark,paper}, vh-monogram-gold. Les deux placeholders, eux, sont bien utilisés via interpolation (shared/card.js:40).	
Constat	Déclinaisons de charte jamais câblées dans le site.	
Impact	Faible : ce sont de petits fichiers. Bruit dans l'arborescence et ambiguïté sur le logo de référence.	
Correctif	Déplacer dans un dossier brand-kit hors du répertoire servi, ou supprimer.	
Effort	S — moins d'une heure	
Décision	Écarté à la demande : ces 17 fichiers sont un stock de déclinaisons de charte conservé pour un usage futur, pas un oubli.	
INFO	ARCH-03 — Trois feuilles de style dépassent le seuil de 800 lignes du projet	OUVERT
Fichier	frontend/css/shared-base.css : ligne —	
Preuve	wc -l : shared-base.css 1338, timeline.css 993, details.css 991. Aucun fichier JS ne dépasse le seuil (plus gros : routes/airplanes.js 651, app.js 580, favorites.js 588).	
Constat	La règle interne des 800 lignes est tenue partout sauf sur ces trois feuilles.	
Impact	Lisibilité de la feuille partagée, chargée sur toutes les pages.	
Correctif	Découper shared-base.css par domaine au prochain passage sur le CSS.	
Effort	M — une demi-journée à deux jours	

2. HTML & sémantique

Score : 100 → 100/100 — 1 info · 1 corrigé(s), 0 ouvert(s)

INFO	HTML-01 — Séparateurs de titres incohérents entre pages	CORRIGÉ
Fichier	frontend/index.html : ligne —	
Preuve	Relevé des 18 <title> : « Vol d'Histoire - Explorez... » et « Mes Favoris - Vol d'Histoire » utilisent un tiret, les 14 autres une barre verticale.	
Constat	Deux conventions de séparateur coexistent dans les titres de page.	
Impact	Cosmétique, visible dans les résultats de recherche et les onglets.	
Correctif	Uniformiser sur « ».	
Effort	S — moins d'une heure	
Appliqué	frontend/index.html et favorites.html, plus les valeurs correspondantes dans fr.json et en.json : séparateur unifié sur « ».	

Vérifié et conforme

- html-validate : 0 erreur sur les 18 pages (configuration html-validate:recommended).
- Exactement un <h1> par page dans le HTML source ; lang, charset et viewport présents partout, sans user-scalable=no.

3. CSS & design system

Score : 88 → 100/100 — 1 majeur · 3 mineur · 1 info · 4 corrigé(s), 1 ouvert(s)

MAJEUR	CSS-01 — style-hero.css est toujours empaqueté alors que sa structure a disparu	CORRIGÉ
Fichier	scripts/build-css.js : ligne 44	
Preuve	'style-hero.css' figure toujours dans le bundle home.min.css. Or grep sur frontend/*.html et frontend/js (hors dist) : hero-title 0, hero-video 0, hero-hud-grid 0, btn-outline 0. index.html:104 utilise la structure hero-split, qui a sa propre feuille (style-hero-split.css, ligne 47 du même bundle).	
Constat	La feuille (344 lignes) sert l'ancienne structure de hero, remplacée par hero-split. Quelques sélecteurs subsistent ailleurs (hero-content, hero-badge : une occurrence chacun), donc la suppression sèche est à écarter — c'est une passe de purge qu'il faut.	
Impact	Poids mort expédié à chaque chargement de l'accueil, et confusion de maintenance : deux systèmes de hero cohabitent dans le bundle.	
Correctif	Purger les sélecteurs morts, déplacer les deux ou trois encore utilisés vers la feuille appropriée, puis retirer la ligne 44 de build-css.js.	
Effort	M — une demi-journée à deux jours	
Appliqué	frontend/css/style-hero.css purgée par analyse sélecteur par sélecteur : 8,8 → 4,3 Ko, 24 règles mortes retirées. Le JS mort associé (.scroll-indicator, absent de tout HTML) est supprimé de script.js.	
MINEUR	CSS-02 — Le bloc d'arrière-plan flouté est dupliqué à l'identique dans cinq feuilles	CORRIGÉ
Fichier	frontend/css/details.css : ligne 203-219 (+ favorites.css:11, legal.css:7, settings.css:9, hangar.css:18)	
Preuve	La déclaration blur(30px) brightness(0.28) saturate(0.7) apparaît une fois dans chacune des cinq feuilles — ≈75 lignes dupliquées. La divergence a déjà commencé : legal.css et settings.css ajoutent background: transparent sur .hero-background, pas hangar.css ni favorites.css.	
Constat	Aucune source unique pour un effet visuel partagé par cinq pages.	
Impact	Toute retouche doit être répétée cinq fois ; l'écart constaté montre que ça n'est déjà plus fait.	
Correctif	Extraire dans shared-base.css sous une classe unique, et supprimer les copies.	
Effort	S — moins d'une heure	
Appliqué	frontend/css/shared-base.css — source unique du fond photographique flouté pour les cinq pages concernées ; les copies de details.css, favorites.css, legal.css, settings.css et hangar.css sont supprimées. Gain net 2,5 Ko.	
MINEUR	CSS-03 — Deux systèmes d'empilement coexistent : tokens z-index et valeurs magiques	CORRIGÉ
Fichier	frontend/css/tokens.css : ligne 255-258	
Preuve	Les tokens existent (sticky 100 / header 1000 / dropdown 2000 / modal 10000) mais ne sont consommés que 9 fois. Plus de 70 déclarations z-index en valeurs littérales : 10000 et 9999 en dur, 5000 (timeline.css:55), 999 (favorites.css:254, hangar.css:164), 900 (hangar.css:340, timeline.css:805).	
Constat	L'échelle documentée est court-circuitée dans la majorité des cas.	
Impact	Recouvrements imprévisibles — le projet en a déjà fait les frais en v4.8.0 avec la bannière de consentement passant devant la barre du comparateur.	
Correctif	Remplacer progressivement les valeurs littérales par les tokens, en commençant par les modales et bandeaux.	
Effort	M — une demi-journée à deux jours	
Appliqué	frontend/css/tokens.css — échelle complétée (--z-raised 900, --z-panel 999, --z-hud 5000, --z-overlay 9999). 15 valeurs littérales remplacées par le token de valeur strictement identique : aucun changement visuel.	

MINEUR	CSS-04 — La police Orbitron est déclarée dans les styles mais n'est jamais chargée	CORRIGÉ
Fichier	frontend/css/style-hero-split.css : ligne 138 (aussi style-sections.css)	
Preuve	font-family: 'Orbitron', 'DM Sans', sans-serif; — grep « Orbitron » dans css/fonts.css : 0 ; ls frontend/fonts/ : BarlowCondensed-400/500/600/700.woff2 et DMSans.woff2 uniquement ; aucun appel à un service de polices distant	
Constat	Aucun @font-face, aucun fichier, aucun chargement externe : le rendu retombe silencieusement sur DM Sans. La documentation du projet présente pourtant Orbitron comme une des trois polices de l'identité.	
Impact	L'identité typographique décrite n'existe pas à l'écran. Aucun coût de performance (rien n'est téléchargé).	
Correctif	Trancher : héberger Orbitron en woff2 local comme les autres, ou retirer la mention des piles de polices et de la documentation.	
Effort	S — moins d'une heure	
Appliqué	style-hero-split.css:138 et style-sections.css (2 occurrences) — Orbitron retirée des piles de polices, qui déclarent désormais DM Sans, effectivement rendu. Héberger la vraie Orbitron reste un choix de design, non traité ici.	

INFO	CSS-05 — Approche desktop-first, contrairement au mobile-first documenté	OUVERT
Fichier	frontend/css/ : ligne —	
Preuve	Sur 88 media queries : 67 max-width contre 9 min-width. Sept valeurs hors de l'échelle déclarée dans tokens.css:8-13 : 37.5em (contact.css:100), 600px (details-lineage.css:102), 1024px et 640px (shared-base.css:1326,1332), 70em (style-hero-split.css:352), 1280px (style-sections.css:69), 47.99em (nations-map.css:205).	
Constat	Écart entre la documentation d'architecture et la pratique réelle, plus quelques points de rupture ad hoc.	
Impact	Aucun défaut visible constaté ; coût de compréhension pour un nouvel arrivant.	
Correctif	Aligner la documentation sur la réalité, ou converger vers l'échelle de tokens lors des prochaines retouches.	
Effort	M — une demi-journée à deux jours	

4. JavaScript

Score : 94 → 100/100 — 1 majeur · 2 info · 3 corrigé(s), 0 ouvert(s)

MAJEUR	JS-01 — 10 vulnérabilités connues dans les dépendances de production, dont 3 « high »	CORRIGÉ
Fichier	backend/package.json : ligne —	
Preuve	npm audit --omit=dev : {low: 1, moderate: 6, high: 3, total: 10}. High : nodemailer <=9.0.0 (installé 8.0.7), ip-address <=10.3.0 (via express-rate-limit), brace-expansion (via @sentry/node → @fastify/otel → minimatch). Moderate : qs, @opentelemetry/* ×4, uuid/hyperid. Low : body-parser.	
Constat	La documentation du projet affirme que « npm audit --omit=dev reste clean » : ce n'est plus le cas. Les paquets racine (5 vulnérabilités) et frontend (5) sont en dev uniquement.	
Impact	nodemailer : les CVE visent jsonTransport, l'option raw et les en-têtes List-*, qu'aucun code du projet n'utilise — risque latent, pas immédiat. ip-address : une IP forgée mal classifiée pourrait contourner la clé de limitation de débit du login, donc faciliter une attaque par force brute. À confirmer par un test dédié.	
Correctif	npm audit fix pour les correctifs non cassants (ip-address, brace-expansion, qs, body-parser), puis planifier séparément nodemailer 8.x → 10.x (changement cassant : vérifier createTransport et sendMail).	
Effort	M — une demi-journée à deux jours	
Appliqué	npm audit fix (ip-address, brace-expansion, qs, body-parser) puis nodemailer 8.0.7 → 10.0.1. L'API utilisée par mailer.js — createTransport et sendMail — est inchangée, vérifiée au chargement et par les 555 tests. npm audit --omit=dev : 0 vulnérabilité.	

INFO	JS-02 — Une erreur 401 est journalisée en console à chaque visite anonyme	CORRIGÉ
Fichier	frontend/js/auth.js : ligne —	
Preuve	Lighthouse errors-in-console (score 0) : « Failed to load resource: the server responded with a status of 401 (Unauthorized) ». Reproduit sur toutes les pages en navigation anonyme.	
Constat	La tentative de rafraîchissement de session d'un visiteur non connecté produit un 401 attendu, mais visible en console.	
Impact	Aucun effet fonctionnel. Bruit qui masque de vraies erreurs pendant le débogage, et pénalise le score « bonnes pratiques ».	
Correctif	Ne tenter le rafraîchissement que si un indice de session existe, ou traiter le 401 sans le laisser remonter en erreur réseau.	
Effort	S — moins d'une heure	
Appliqué	backend/middleware/auth.js — témoin de session vh_session (non httpOnly, non sensible, même durée que le refresh token) posé et effacé avec lui ; frontend/js/auth.js le consulte avant de tenter un rafraîchissement. Lighthouse bonnes pratiques : 96 → 100.	

INFO	JS-03 — L'appareil du jour change si le catalogue change dans la journée	CORRIGÉ
Fichier	frontend/js/home/hero-daily.js : ligne 47-50	
Preuve	return hashSeed(dayKey) % length; — observé pendant l'audit : l'appareil du jour est passé de sea-harrier à h6 après l'insertion de 4 fiches par le seed E2E	
Constat	Le tirage est un index modulo la longueur de la liste : ajouter ou retirer une fiche décale tous les index.	
Impact	Faible — le catalogue évolue par lots. Un lien partagé « l'appareil du jour » peut toutefois ne plus correspondre.	
Correctif	Tirer sur l'identifiant plutôt que sur la position : choisir l'appareil dont hash(id + jour) est minimal, stable à l'ajout d'une fiche.	
Effort	S — moins d'une heure	
Appliqué	frontend/js/home/hero-daily.js — pickDaily retient l'appareil dont hash(jour + identifiant) est minimal, au lieu d'un index modulo la longueur. Trois tests ajoutés, dont la stabilité sur 28 jours quand le catalogue passe de 383 à 387 fiches.	

Vérifié et conforme

- Aucun eval, new Function, document.write, insertAdjacentHTML ni outerHTML dans les sources. Les 113 usages d'innerHTML passent par escapeHtml ou DOMPurify (utils.js:33-53).

5. Performance

Score : 82 → 94/100 — 3 majeur · 3 mineur · 2 info · 5 corrigé(s), 3 ouvert(s)

MAJEUR	PERF-08 — Le LCP reste à 4,2 s, désormais bloqué par le rendu du titre	OUVERT
Fichier	frontend/index.html : ligne 105-112	
Preuve	Lighthouse 12.8.2 après correctifs, décomposition du LCP : TTFB 454 ms (11 %), Load Delay 0 ms, Load Time 0 ms, Render Delay 3754 ms (89 %). Élément : h1.hero-split-title. Mesure reproductible à 1 ms près sur trois exécutions (4207 / 4208 / 4208 ms).	
Constat	La conversion de l'image du quiz en AVIF (PERF-02) a bien sorti l'image de la position LCP — c'est maintenant le titre de l'accueil. Mais le temps total n'a pas bougé : le retard s'est déplacé du chargement de l'image vers le rendu du titre, où il représente 89 % du délai.	
Impact	Seul indicateur Core Web Vitals dans le rouge. Les autres sont bons : CLS 0,000 et TBT 55 ms après correctifs.	
Correctif	Investiguer séparément. Deux pistes à mesurer : l'animation .gradient-text de style-hero-split.css, dont le fill-mode both et le délai de 0,7 s laissent le texte transparent au premier rendu ; et le remplacement de texte opéré par i18n.js après chargement des locales, qui redéclenche une candidature LCP.	
Effort	M — une demi-journée à deux jours	

MAJEUR	PERF-01 — Trois images sont préchargées en priorité haute et ne sont affichées nulle part	CORRIGÉ
Fichier	frontend/js/script.js : ligne 134-147	
Preuve	const preloadImages = ['/assets/airplanes/f16-fighting-falcon.jpg', '/assets/airplanes/mig21.jpg', '/assets/airplanes/su27.jpg']; — recherche sur tout frontend/*.html et frontend/js/**/*.js : ces trois noms n'apparaissent nulle part ailleurs. Lighthouse les chiffre à 120 + 117 + 111 Ko.	
Constat	Elles sont injectées en <link rel=preload as=image> sur l'accueil, qui affiche en réalité rafale, f22-raptor et mig29.	
Impact	≈348 Ko téléchargés en priorité haute à chaque visite de l'accueil, pour rien, en concurrence directe avec l'élément LCP mesuré à 4,1 s.	
Correctif	Supprimer le bloc lignes 134-147. Si un préchargement est souhaité, le cibler sur l'image réellement en LCP.	
Effort	S — moins d'une heure	
Appliqué	frontend/js/script.js — bloc preloadImages supprimé (14 lignes). Les trois fichiers ne figuraient nulle part ailleurs dans le HTML ou le JS.	

MAJEUR	PERF-02 — L'élément LCP est une image JPEG servie sans AVIF ni WebP	CORRIGÉ
Fichier	frontend/index.html : ligne 164 (et frontend/js/script.js:469)	
Preuve	Lighthouse 12.8.2 : LCP = 4,1 s (score 0,46), élément = aside.hero-aside-stack > article#hero-quiz-card > ... > IMG. index.html:164 = ; script.js:469 = image.src = current.image_url. Audit modern-image-formats : 536 Kio d'économie estimée.	
Constat	Le projet génère pourtant .avif et .webp pour les 383 fiches et dispose du helper VH.shared.picture, utilisé par card.js:41, timeline.js:86 et details/render.js:45. L'image du quiz est le seul visuel majeur resté en JPEG nu.	
Impact	LCP à 4,1 s en émulation mobile : seul indicateur Core Web Vitals dans le rouge (CLS 0,005 et TBT 90 ms sont excellents).	
Correctif	Appliquer VH.shared.picture.applySourcesTo() à #hero-quiz-image, comme details/render.js:45 le fait pour le hero de fiche.	
Effort	S — moins d'une heure	
Appliqué	frontend/js/script.js — l'image du quiz passe par VH.shared.picture.applySourcesTo(), comme le hero de fiche. Effet mesuré : économies d'images potentielles 536 → 239 Kio, et l'élément LCP n'est plus l'image.	

MINEUR	PERF-05 — Le sous-ensemble d'icônes pèse 79 % du bundle partagé	CORRIGÉ
Fichier	frontend/js/icons.js : ligne —	
Preuve	icons.js = 87,8 Ko de source ; app.min.js = 111,6 Ko minifié, chargé sur toutes les pages	
Constat	Les 164 icônes SVG sont embarquées dans le bundle commun, alors qu'aucune page ne les utilise toutes.	
Impact	Poids constant sur le chemin critique de chaque page du site.	
Correctif	Sortir icons.js du bundle commun et le charger en différé, ou générer un sous-ensemble par page (build-icons.py connaît déjà les classes utilisées).	
Effort	M — une demi-journée à deux jours	
Appliqué	scripts/build-js.js — icons.js sort du bundle commun vers icons.min.js, chargé en defer sur les 16 pages. app.min.js : 111,6 → 27,5 Ko. Choix validé par A/B Lighthouse (2 exécutions par variante) : séparé donne 4207 ms de LCP contre 4430 ms fusionné.	

MINEUR	PERF-03 — Le préchargement d'image du <head> ne vise pas l'élément LCP	CORRIGÉ
Fichier	frontend/index.html : ligne 41	
Preuve	<link rel="preload" as="image" href="/assets/airplanes/rafale.avif" ... fetchpriority="high"> — or rafale.avif est l'image de la première carte « Avions en vedette » (l.202), plus bas dans la page	
Constat	La priorité réseau est donnée à une image qui n'est pas celle qui décide du LCP.	
Impact	Bande passante prioritaire mal allouée au premier rendu.	
Correctif	À traiter avec PERF-02 ; le LCP dépendant d'un appel API, viser d'abord la conversion AVIF.	
Effort	S — moins d'une heure	
Appliqué	frontend/index.html:41 — le <link rel=preload> de rafale.avif est retiré, avec un commentaire expliquant pourquoi l'élément LCP de cette page ne peut pas être préchargé : il dépend d'un appel API.	

MINEUR	PERF-04 — Cache navigateur d'un jour sur des URL déjà versionnées	CORRIGÉ
Fichier	backend/app.js : ligne 303	
Preuve	res.setHeader('Cache-Control', 'public, max-age=86400, s-maxage=604800'); — Lighthouse : « uses-long-cache-ttl : 21 resources found ». Les URL servis portent pourtant ?v=4.9.0 (vérifié dans le HTML rendu).	
Constat	Le commentaire du code qualifie ces fichiers de « statiques fingerprintables », mais ils n'obtiennent qu'un jour de cache.	
Impact	Revalidation quotidienne inutile de 111 Ko d'app.min.js et des feuilles de style pour les visiteurs récurrents.	
Correctif	Servir les fichiers portant ?v= avec max-age=31536000, immutable ; conserver le cache court pour les assets non versionnés.	
Effort	S — moins d'une heure	
Appliqué	backend/app.js — les .css et .js, dont l'URL porte déjà ?v=<version>, passent en max-age=31536000, immutable ; les images gardent la journée. Lighthouse : ressources à cache court 21 → 10. Trois tests d'en-têtes mis à jour.	

INFO	PERF-06 — 430 ms de CSS bloquant le rendu sur l'accueil	OUVERT
Fichier	frontend/index.html : ligne 42-43	
Preuve	Lighthouse render-blocking-resources : home.min.css 307 ms (10 Ko) + core.min.css 157 ms (13 Ko)	
Constat	Deux feuilles bloquantes dans le <head>, de tailles raisonnables ; le coût vient surtout de la latence.	
Impact	Retarde le premier rendu, mais FCP mesuré à 1,2 s (score 0,99).	
Correctif	Optionnel : inliner le CSS critique du hero et charger le reste en asynchrone.	
Effort	M — une demi-journée à deux jours	

INFO	PERF-07 — 119 Mo d'images dans le dépôt, en triple exemplaire	OUVERT
Fichier	frontend/assets/airplanes/ : ligne —	
Preuve	du : 383 JPEG (54,8 Mo) + 383 WebP (38,3 Mo) + 383 AVIF (22,5 Mo) = 115,6 Mo ; plus lourde : t6-texan2.jpg (468 Ko)	
Constat	Les trois formats coexistent, ce qui est nécessaire au <picture> avec repli. Le JPEG de repli reste le plus lourd des trois.	
Impact	Poids de dépôt et de déploiement, sans effet sur le visiteur (qui ne télécharge qu'un format).	
Correctif	Aucune action requise. À surveiller si le catalogue double : envisager un stockage d'objets plutôt que le dépôt Git.	
Effort	L — au-delà	

Vérifié et conforme

- CLS 0,005 et TBT 90 ms mesurés par Lighthouse ; polices auto-hébergées en woff2 avec font-display: swap et preload des deux plus critiques ; aucun contenu mixte http:// dans les sources.

6. Accessibilité

Score : 41 → 100/100 — 1 critique · 6 majeur · 7 mineur · 14 corrigé(s), 0 ouvert(s)

CRITIQUE	A11Y-01 — Le lien d'évitement du hangar ne mène nulle part, et la page n'a aucun <main>	CORRIGÉ
Fichier	frontend/hangar.html : ligne 70	
Preuve	Aller au contenu — c'est la SEULE occurrence de « main-content » du fichier ; grep « <main » sur hangar.html : 0 résultat. Les 10 autres pages complètes ont bien <main id="main-content"> (index.html:103, details.html:201, settings.html:71...).	
Constat	Le contenu principal est une <section class="hangar-content"> (l.137) sans id ni rôle. Le premier élément focusable de la page pointe vers une ancre inexistante.	
Impact	Sur la page la plus utilisée du site, les utilisateurs clavier et lecteur d'écran n'ont aucun moyen de contourner l'en-tête et la navigation, et aucune région principale à cibler. Échec WCAG 2.4.1 (niveau A) et 1.3.1.	
Correctif	Ajouter id="main-content" sur la section, ou l'englober dans <main id="main-content">. Une ligne.	
Effort	S — moins d'une heure	
Appliqué	frontend/hangar.html:137 — <section class="hangar-content"> devient <main id="main-content" class="hangar-content">, fermeture ajustée ligne 195. Le lien d'évitement pointe enfin sur une ancre existante.	
MAJEUR	A11Y-02 — Contraste insuffisant sur 6 libellés de la page Paramètres	CORRIGÉ
Fichier	frontend/css/settings.css : ligne 61 et 54	
Preuve	axe-core 4.13.0 : 6 occurrences de color-contrast. Ratios mesurés 3,19:1 / 3,21:1 (#656565 sur #121212, 12,8 px) et 3,44:1 (#c0392b sur #121212, 15,2 px) pour un minimum de 4,5:1. settings.css:61 = .link-description { color: rgba(255,255,255,0.35) } ; settings.css:54 = .sidebar-link.danger-link { color: var(--accent) }	
Constat	Seule violation relevée par axe sur les 11 pages testées. Concerne les descriptions de la barre latérale et l'entrée « zone de danger ».	
Impact	Texte difficilement lisible pour les personnes malvoyantes ou sur écran peu contrasté. Échec WCAG 1.4.3 niveau AA.	
Correctif	.link-description à rgba(255,255,255,0.55) (≈4,6:1) ; éclaircir l'accent rouge pour cet usage sur fond sombre (#e74c3c donne ≈4,6:1).	
Effort	S — moins d'une heure	
Appliqué	frontend/css/settings.css:61 — .link-description passe à rgba(255,255,255,0.55), soit 6,2:1 mesuré. tokens.css — nouveau --accent-text #E74C3C (4,9:1) utilisé par .danger-link, l'ancien --accent restant pour les fonds et bordures.	
MAJEUR	A11Y-14 — Cases du comparateur à 18 × 18 px sur les cartes du hangar	CORRIGÉ
Fichier	frontend/css/hangar.css : ligne 441-460	
Preuve	axe-core, passe de vérification : 3 occurrences de target-size sur input[data-compare-id]. La taille par défaut du navigateur (18 px) s'appliquait, aucune règle ne la fixant.	
Constat	Constat absent du premier passage : les cartes n'étaient pas rendues au moment où axe a analysé le hangar, faute de données en base locale. Le second passage, avec un catalogue peuplé, l'a fait apparaître.	
Impact	Cible sous le minimum de 24 × 24 px du critère WCAG 2.5.8, sur une action fréquente et répétée : sélectionner des appareils à comparer.	
Correctif	Fixer width et height à 24 px sur .compare-check input, dans les trois contextes (grille, liste, mobile).	
Effort	S — moins d'une heure	
Appliqué	frontend/css/hangar.css — les trois règles de .compare-check input passent à 24 × 24 px (vue grille, vue liste et palier mobile).	

MAJEUR	A11Y-03 — L'indicateur de focus est quasi invisible sur les champs de recherche et de formulaire	CORRIGÉ
Fichier	frontend/css/hangar.css : ligne 97, 144, 249 (+ favorites.css:210,277 ; settings.css:85,129 ; details.css:373)	
Preuve	input:focus { outline: none; border-color: rgba(255,255,255,0.2); box-shadow: 0 0 3px rgba(255,255,255,0.04); } — 8 règles au même motif, sans garde :focus-visible	
Constat	Ces règles suppriment le contour natif sans le remplacer par un indicateur suffisant : une bordure blanche à 20 % d'opacité et une ombre à 4 % sur un fond #141414. Contraste estimé par composition alpha $\approx 1,9:1$, contre 3:1 exigé. Estimation calculée, non mesurée à l'écran — la marge reste large. Le reste du projet applique pourtant correctement :focus:not(:focus-visible) (base.css:32-35, login.css:306-322, contact.css:149-157).	
Impact	Les utilisateurs clavier perdent la trace du focus sur les champs des pages hangar, favoris, paramètres et fiche. Échec WCAG 2.4.7 et 1.4.11.	
Correctif	Aligner ces 8 règles sur le motif :focus-visible déjà employé ailleurs dans le projet.	
Effort	S — moins d'une heure	
Appliqué	8 règles alignées (hangar.css:97,144,249 ; favorites.css:210,277 ; settings.css:85,129 ; details.css:373) : bordure de focus portée de 0,2 à 0,45 d'opacité, ombre de 0,04 à 0,12. shared-base.css — anneau :focus-visible explicite (2 px hud-cyan) sur input, select et textarea.	

MAJEUR	A11Y-04 — Trois pages perdent leur unique <h1> dans l'état que voit l'utilisateur	CORRIGÉ
Fichier	frontend/forgot-password.html : ligne 157 vs 176 (idem reset-password.html:191/182, verify-email.html:130/138)	
Preuve	Le <h1> est dans #fp-form-section (l.156-157) ; js/forgot-password.js:51-52 fait formSection.style.display = 'none' puis successEl.style.display = 'block', et #fp-success ne contient qu'un <h2> (l.176). Même schéma dans reset-password.js:7-8 et verify-email.js.	
Constat	Dans l'état final (succès, erreur, lien invalide) — celui que voit la majorité des utilisateurs — la page n'a plus aucun titre de niveau 1.	
Impact	Navigation par titres incohérente pour les lecteurs d'écran. Échec WCAG 1.3.1 / 2.4.6.	
Correctif	Conserver un conteneur de titre unique dont le niveau ne change pas selon l'état, ou promouvoir les <h2> de succès/erreur en <h1>.	
Effort	S — moins d'une heure	
Appliqué	forgot-password.html:176, reset-password.html:182 et verify-email.html — les titres des états terminaux passent en <h1>. Un seul est visible à la fois, l'autre conteneur étant masqué.	

MAJEUR	A11Y-05 — Boutons de suppression de filtre à 18 × 18 px	CORRIGÉ
Fichier	frontend/css/hangar.css : ligne 151 (et favorites.css:272)	
Preuve	.page-hangar .remove-filter-btn { ... width: 18px; height: 18px; ... } — vrai <button> généré par js/hangar/filters.js:81 et js/favorites.js:385, sans padding compensatoire	
Constat	Sous le minimum de 24 × 24 px du critère 2.5.8, nouveau en WCAG 2.2. Aucune des exceptions ne s'applique : ce n'est ni un lien en ligne, ni un contrôle natif du navigateur.	
Impact	Cible trop petite au doigt et pour les utilisateurs à motricité réduite, sur une action fréquente (retirer un filtre).	
Correctif	Porter à 28 × 28 px, comme .close-dropdown (hangar.css:171) qui est déjà conforme.	
Effort	S — moins d'une heure	
Appliqué	frontend/css/hangar.css:151 et favorites.css:272 — .remove-filter-btn passe de 18 × 18 à 28 × 28 px.	

MAJEUR	A11Y-06 — Deux animations en boucle infinie sans garde prefers-reduced-motion	CORRIGÉ
Fichier	frontend/css/cookies.css : ligne 62 (et login.css:95)	
Preuve	cookies.css:62 : animation: bounce 2s infinite; (icône du bandeau, affiché sur toutes les pages tant que le consentement n'est pas donné) ; login.css:95 : animation: dotBlink 3s ease-in-out infinite; — grep prefers-reduced-motion : 0 occurrence dans ces deux feuilles	
Constat	Le reste du projet couvre pourtant bien cette préférence (15 feuilles la respectent). Ces deux animations démarrent seules, durent indéfiniment et s'affichent à côté du contenu principal.	
Impact	Gêne pour les personnes sensibles au mouvement. Échec WCAG 2.2.2, niveau A.	
Correctif	@media (prefers-reduced-motion: reduce) { .cookie-icon, .radar-dot { animation: none; } }	
Effort	S — moins d'une heure	
Appliqué	frontend/css/cookies.css et login.css — blocs @media (prefers-reduced-motion: reduce) ajoutés, neutralisant l'icône rebondissante du bandeau et le clignotement des points du radar.	

MINEUR	A11Y-07 — Sauts de niveaux de titres sur quatre pages	CORRIGÉ
Fichier	frontend/cgu.html : ligne 97 → 119 (idem politique-confidentialite.html, hangar.html:115→145, details.html:204→205)	
Preuve	cgu.html : <h1> l.97, puis <h3> l.119, le premier <h2> n'arrivant qu'à la l.126. hangar.html : <h1> l.115 puis trois <h3> (l.145, 149, 153), premier <h2> à la l.202 (modale). details.html : <h2> « Dates Clés » l.204 suivi directement de <h4> l.205-207.	
Constat	La hiérarchie annoncée aux technologies d'assistance ne reflète pas l'imbrication réelle du contenu.	
Impact	Un utilisateur qui navigue de titre en titre ne peut pas déduire la structure. Échec WCAG 1.3.1.	
Correctif	Reclasser les h3/h4 orphelins au niveau immédiatement inférieur au titre précédent.	
Effort	M — une demi-journée à deux jours	
Appliqué	hangar.html (3 titres de filtre h3 → h2), details.html (3 h4 → h3), cgu.html (h3 d'intro → h2, 6 h4 → h3), politique-confidentialite.html (h3 d'intro → h2, 21 h4 → h3), 404.html (titre de section masqué en .sr-only). Contrôle automatisé : plus aucun saut de niveau sur les 18 pages.	

MINEUR	A11Y-08 — Un <h2> décoratif précède le <h1> sur la page de connexion	CORRIGÉ
Fichier	frontend/login.html : ligne 118	
Preuve	<h2 class="visual-title">Vol d'Histoire</h2> (l.118) apparaît avant <h1 data-i18n="login.login_title">Identification</h1> (l.177)	
Constat	Le premier titre rencontré par un lecteur d'écran est un h2 appartenant au panneau visuel décoratif.	
Impact	Hiérarchie sans racine cohérente en tête de page.	
Correctif	Passer .visual-title en <p> ou stylé : c'est un ornement, pas un titre de section.	
Effort	S — moins d'une heure	
Appliqué	frontend/login.html:118 — le titre décoratif du panneau visuel passe de <h2> à <p>, la classe et donc le style restant identiques.	

MINEUR	A11Y-09 — Landmark <main> absent sur les quatre pages d'authentification	CORRIGÉ
Fichier	frontend/check-email.html : ligne 162 (idem forgot-password:152, reset-password:175, verify-email:124)	
Preuve	Les quatre utilisent <div id="main-content"> ; grep « <main » : 0 sur les quatre fichiers	
Constat	Le lien d'évitement fonctionne (la cible existe), mais la navigation par régions ne trouve pas de contenu principal.	
Impact	Gêne modérée pour les lecteurs d'écran, sur des pages de passage.	
Correctif	Remplacer le <div> par <main>.	
Effort	S — moins d'une heure	
Appliqué	check-email.html:162, forgot-password.html:152, reset-password.html:175, verify-email.html:124 — <div id="main-content"> devient <main>, fermetures ajustées.	

MINEUR	A11Y-10 — role="alert" doublé d'un aria-live="polite" contradictoire	CORRIGÉ
Fichier	frontend/contact.html : ligne 175 et 190 (+ forgot-password.html:160, reset-password.html:194)	
Preuve	 — 4 occurrences	
Constat	role="alert" implique aria-live="assertive" ; y adjoindre « polite » est contradictoire et le comportement retenu varie selon la technologie d'assistance.	
Impact	Urgence d'annonce des erreurs de formulaire imprévisible.	
Correctif	Retirer aria-live="polite" : le rôle suffit.	
Effort	S — moins d'une heure	
Appliqué	contact.html:175 et 190, forgot-password.html:160, reset-password.html:194 — aria-live="polite" retiré ; role="alert" porte déjà la sémantique assertive.	

MINEUR	A11Y-11 — Le graphique radar SVG n'est ni masqué ni décrit	CORRIGÉ
Fichier	frontend/js/details/radar.js : ligne 74	
Preuve	<svg viewBox="0 0 300 300" ... class="radar-svg"> — sans aria-hidden ni role/aria-label ; la légende équivalente est bien construite lignes 96-104	
Constat	Le SVG expose les libellés d'axes sans les valeurs ; l'équivalent textuel complet existe juste à côté dans #radar-legend.	
Impact	Annonce partielle et redondante pour les lecteurs d'écran qui explorent le SVG.	
Correctif	Ajouter aria-hidden="true" sur le <svg>, la légende portant déjà l'information.	
Effort	S — moins d'une heure	
Appliqué	frontend/js/details/radar.js:74 — le <svg> reçoit aria-hidden="true" et focusable="false" ; la légende adjacente porte déjà les valeurs en texte.	

MINEUR	A11Y-12 — Liens d'action sous la hauteur de cible de 24 px	CORRIGÉ
Fichier	frontend/css/style-sections.css : ligne — (.feature-link, .aircraft-btn, .forgot-password, fil d'Ariane)	
Preuve	Mesure Playwright (getBoundingClientRect) à 1440 px et 390 px : .feature-link 206×23, .aircraft-btn 133×21, #hero-fact-link 98×21, .forgot-password 130×20, lien « Accueil » du fil d'Ariane 83×20	
Constat	Largeur confortable, hauteur de 20 à 23 px, sous le seuil de 24 px du critère 2.5.8.	
Impact	Plusieurs bénéficient probablement de l'exception d'espacement (pas de cible voisine dans un rayon de 24 px) : la conformité formelle dépend de cet espacement, non mesuré ici.	
Correctif	min-height: 24px et un padding vertical sur ces classes — plus simple que de démontrer l'exception.	
Effort	S — moins d'une heure	
Appliqué	frontend/css/shared-base.css — min-height: 24px et inline-flex sur .feature-link, .aircraft-btn, .hero-aside-link, .forgot-password et les liens du fil d'Ariane.	

MINEUR	A11Y-13 — Lien externe en nouvel onglet sans avertissement ni rel="noopener"	CORRIGÉ
Fichier	frontend/politique-confidentialite.html : ligne 563	
Preuve	www.cnil.fr — seule occurrence de target="_blank" des 18 pages	
Constat	Ni indication textuelle, ni aria-label, ni rel="noopener".	
Impact	Changement de contexte inattendu, non annoncé aux lecteurs d'écran.	
Correctif	Ajouter rel="noopener" et une mention « (nouvel onglet) » visuellement masquée.	
Effort	S — moins d'une heure	
Appliqué	frontend/politique-confidentialite.html:563 — rel="noopener noreferer" ajouté et mention « (nouvel onglet) » en .sr-only, avec la clé i18n legal.new_tab dans les deux langues.	

Vérfié et conforme

- axe-core 4.13.0 (WCAG 2.0/2.1/2.2 A + AA) sur 11 pages : une seule violation, le contraste de settings (A11Y-02). Accueil, hangar, chronologie, connexion, contact, favoris, pages légales et 404 sortent à zéro violation.
- Lighthouse accessibilité : 100/100 sur l'accueil.
- Tous les du HTML source ont un alt ; aucun bouton ou lien à icône seule sans aria-label.
- Formulaire : chaque champ a un <label for> correspondant ou un label englobant, sur contact, login, settings, forgot-password et reset-password.
- Onglets ARIA complets (tablist/tab/tabpanel, aria-selected, tabindex roving, inert sur le panneau inactif) sur login.html:159-228 et settings.html:97-230 ; modales avec role=dialog + aria-modal + aria-labelledby ; navigation clavier flèches et Échap sur les menus déroulants (js/nav.js:149-185).
- Lien d'évitement et <main id="main-content"> présents et corrects sur 10 des 12 pages applicatives complètes.

7. Sécurité

Score : 82 → 98/100 — 2 majeur · 3 mineur · 1 info · 4 corrigé(s), 2 ouvert(s)

MAJEUR	SEC-01 — Le scrubbing des logs est contourné sur le chemin Sentry	CORRIGÉ
Fichier	backend/logger.js : ligne 80-84	
Preuve	<code>l.66 : const safeMeta = (meta && scrub) ? scrub(meta) : meta; — l.80-84 : Object.entries(meta).forEach(([k, v]) => { if (k !== 'error') scope.setExtra(k, v); })</code>	
Constat	log() calcule safeMeta et l'utilise pour la sortie console/JSON, correctement épurée des mots de passe, jetons et cookies. Le transfert vers Sentry, lui, réutilise la variable meta BRUTE. Tout appel logger.error('...', { password, token, ... }) enverrait ces valeurs en clair dans les extras Sentry.	
Impact	Des secrets ou données personnelles peuvent quitter le serveur vers un tiers alors que sanitize-logs.js affirme explicitement les protéger. Un jeton de session exposé dans Sentry reste réutilisable.	
Correctif	Remplacer meta par safeMeta lignes 80-84 (scrub() préserve les objets Error, donc safeMeta.error reste exploitable ligne 85).	
Effort	S — moins d'une heure	
Appliqué	backend/logger.js:80-86 — le transfert vers Sentry lit safeMeta (valeur épurée) au lieu de meta. Vérifié : 7 occurrences de safeMeta dans le fichier.	

MAJEUR	SEC-02 — escapeJson n'échappe pas « < » avant injection dans un <script> JSON-LD	CORRIGÉ
Fichier	backend/routes/details-ssr.js : ligne 25-26	
Preuve	<code>return String(str "").replace(/[u0000-u001fu2028u2029]/g, ...) — n'échappe ni < ni /</code>	
Constat	Le JSON-LD rendu côté serveur interpole aircraft.name — modifiable par un rôle éditeur ou admin, sans filtrage de caractères dans validators.js — dans un <script type="application/ld+json">. Une valeur contenant </script><script>... romprait le bloc.	
Impact	XSS stocké déclenchable sans interaction sur /details/:slug. Atténué par la CSP (script-src sans 'unsafe-inline' ni nonce : un script inline injecté est bloqué), mais la défense repose alors entièrement sur elle. Exploitation nécessite un compte éditeur/admin compromis.	
Correctif	Ajouter .replace(/</g, '\u003c') dans escapeJson — pratique standard pour du JSON injecté dans du HTML.	
Effort	S — moins d'une heure	
Appliqué	backend/routes/details-ssr.js:29-31 — escapeJson ajoute .replace(/</g, '\u003c'). Test de non-régression ajouté : un nom contenant </script> ne referme plus le bloc JSON-LD.	

MINEUR	SEC-03 — Comparaison non constante du jeton de supervision	CORRIGÉ
Fichier	backend/routes/monitoring.js : ligne 65 et 83	
Preuve	<code>if (provided !== token) {</code>	
Constat	GET /api/metrics et GET /api/status comparent METRICS_TOKEN avec !==, sensible aux attaques temporelles.	
Impact	Surface faible (endpoints de supervision), jeton théoriquement devinable octet par octet.	
Correctif	crypto.timingSafeEqual, avec égalisation préalable des longueurs.	
Effort	S — moins d'une heure	
Appliqué	backend/routes/monitoring.js — helper tokenEgal() : hachage SHA-256 des deux jetons puis crypto.timingSafeEqual. Appliqué aux deux routes (/api/metrics et /api/status).	

MINEUR	SEC-05 — La CSP autorise picsum.photos, qui n'est plus utilisé nulle part	CORRIGÉ
Fichier	backend/app.js : ligne 80	
Preuve	"img-src 'self' https://flagcdn.com ... https://picsum.photos https://fastly.picsum.photos data:" — grep « picsum » sur frontend/, backend/routes/, backend/db_backup/ : 0 occurrence	
Constat	Reliquat de développement dans la politique de sécurité du contenu.	
Impact	Élargit inutilement la surface autorisée : une injection d'URL d'image pourrait exfiltrer vers un domaine tiers déjà autorisé.	
Correctif	Retirer les deux domaines picsum de img-src.	
Effort	S — moins d'une heure	
Appliqué	backend/app.js:80 — picsum.photos et fastly.picsum.photos retirés de la directive img-src.	

MINEUR	SEC-04 — jwt.verify sans restriction explicite d'algorithme	OUVERT
Fichier	backend/middleware/auth.js : ligne 170 (+ routes/auth.js:192 et 249)	
Preuve	const decoded = jwt.verify(token, process.env.JWT_SECRET);	
Constat	Trois appels ne fixent pas algorithms. jsonwebtoken@9.0.3 avec un secret HMAC n'est pas vulnérable à la confusion d'algorithme : aucune exploitation actuelle.	
Impact	Nul aujourd'hui. Risque latent en cas de migration vers des clés asymétriques.	
Correctif	Ajouter { algorithms: ['HS256'] } aux trois appels.	
Effort	S — moins d'une heure	

INFO	SEC-06 — firstname/lastname du formulaire de contact non validés	OUVERT
Fichier	backend/routes/contact.js : ligne 14 et 27	
Preuve	const safeName = [(firstname "").trim(), (lastname "").trim()].filter(Boolean).join(' ') 'Anonyme';	
Constat	email et message sont validés (isValidEmail, isValidString(5000)), pas ces deux champs. Aucun risque XSS : mailer.js:225 échappe via escapeHtmlEmail, et le corps est borné à 100 Ko.	
Impact	Incohérence de validation aux frontières, aucune vulnérabilité constatée.	
Correctif	Ajouter une validation de longueur (100 caractères).	
Effort	S — moins d'une heure	

Vérifié et conforme

- Requêtes SQL systématiquement paramétrées — aucune concaténation de valeur utilisateur trouvée (routes/auth.js:43,111 ; routes/airplanes.js:505-543 ; routes/users.js:37-46).
- Mots de passe hachés bcrypt coût 12 (routes/auth.js:47), comparaison contre un hash factice si l'utilisateur n'existe pas (auth.js:118-120) pour éviter l'énumération par temps de réponse.
- Verrouillage de compte après 10 échecs pendant 15 min (routes/auth.js:97-98,135-151), réponse identique dans tous les cas d'échec.
- Jeton d'accès de 15 min + refresh token en base, rotation atomique en transaction et détection de rejeu révoquant toutes les sessions (middleware/auth.js:89-106 ; routes/auth.js:211-233).
- Cookie de refresh httpOnly + secure en production + sameSite strict + path limité à /api (middleware/auth.js:143-149) ; le jeton d'accès n'est jamais en localStorage (js/auth.js:5,19).
- Contrôle de propriété sur les ressources utilisateur (isOwnerOrAdmin, middleware/auth.js:192-203) et favoris toujours filtrés par req.user.id — aucun IDOR trouvé.
- En-têtes de sécurité complets, vérifiés sur la réponse HTTP réelle : HSTS preload, X-Frame-Options DENY, X-Content-Type-Options, Referrer-Policy, Permissions-Policy, COOP, CORP, X-Powered-By retiré.

- CSP sans 'unsafe-inline' : nonce sur les styles, style-src-attr 'none', object-src 'none', frame-ancestors 'none', base-uri et form-action 'self'.
- Limitation de débit différenciée par route sensible avec Redis et repli mémoire ; hCaptcha sur inscription, mot de passe oublié et contact ; corps JSON plafonné à 100 Ko.
- Aucun secret en dur : JWT_SECRET et REFRESH_SECRET obligatoires et vérifiés ≥ 32 caractères au démarrage (server.js:5-18) ; *.env gitignoré, seul .env.example versionné.

8. SEO technique

Score : 96 → 100/100 — 2 mineur · 1 info · 2 corrigé(s), 1 ouvert(s)

MINEUR	SEO-01 — Les trois hreflang des fiches pointent vers une URL identique	CORRIGÉ
Fichier	backend/routes/details-ssr.js : ligne 221-233	
Preuve	Les trois remplacements (hreflang fr, en, x-default) reçoivent la même variable url, sans ?lang= — le commentaire du code l'assume explicitement. Les pages statiques, elles, distinguent bien ?lang=fr / ?lang=en (index.html:36-38).	
Constat	Sur le type de page le plus nombreux du site (383 fiches), le balisage multilingue n'apporte aucune information exploitable.	
Impact	Balisage inerte : le moteur ne peut pas distinguer une version FR d'une version EN puisque l'URL est la même.	
Correctif	Injecter ?lang=fr et ?lang=en dans les hreflang de /details, comme sur les pages statiques.	
Effort	S — moins d'une heure	
Appliqué	backend/routes/details-ssr.js:221-233 — les hreflang fr et en reçoivent ?lang=fr et ?lang=en, x-default gardant l'URL nue. Test de non-régression ajouté.	

MINEUR	SEO-02 — datePublished du JSON-LD contient l'année de mise en service de l'avion	CORRIGÉ
Fichier	backend/routes/details-ssr.js : ligne 170	
Preuve	if (year) articleLd.datePublished = `\${year}-01-01`; où year = new Date(aircraft.date_operationel).getFullYear() (l.68-70)	
Constat	Le champ « date de publication » de l'Article est rempli avec une donnée métier de l'appareil, pas avec la date de rédaction de la fiche.	
Impact	Un moteur peut afficher « 1955 » comme date de publication d'une fiche écrite en 2026 : signal de fraîcheur dégradé et information trompeuse.	
Correctif	Omettre datePublished (facultatif pour Article) ou le remplir avec airplanes.created_at / updated_at, qui existent en base.	
Effort	S — moins d'une heure	
Appliqué	backend/routes/details-ssr.js — datePublished vient de airplanes.created_at et dateModified de updated_at (colonnes ajoutées à la requête SSR) au lieu de l'année de mise en service de l'appareil. Deux tests ajoutés, dont le cas sans created_at.	

INFO	SEO-03 — Meta description de la chronologie au-dessus de la limite d'affichage	OUVERT
Fichier	frontend/timeline.html : ligne —	
Preuve	Mesure programmatique sur les 18 pages : timeline.html = 164 caractères ; toutes les autres sont entre 57 et 124.	
Constat	La limite pratique avant troncature dans les résultats de recherche est de 155 à 160 caractères.	
Impact	Risque de troncature de la fin de la description.	
Correctif	Raccourcir de quelques mots.	
Effort	S — moins d'une heure	

Vérifié et conforme

- Lighthouse SEO : 100/100. Les 18 pages ont un <title> unique et non vide ; 14 ont description + canonical + Open Graph ; les 4 pages transactionnelles portent noindex, nofollow, comme login, settings, favoris et 404.
- Rendu serveur dédié aux fiches (details-ssr.js) : title, description, canonical, OG, Twitter et JSON-LD hydratés par appareil, avec redirection 301 des anciennes URL ?id= vers l'URL canonique en slug.
- Sitemap dynamique couvrant les pages publiques et les 383 fiches, avec cache Redis 24 h et repli statique si la base est indisponible ; robots.txt cohérent et déclarant le sitemap.

9. Conformité RGPD

Score : 69 → 100/100 — 1 critique · 2 majeur · 2 mineur · 5 corrigé(s), 0 ouvert(s)

CRITIQUE	RGPD-01 — La garde de consentement de Sentry lit une clé qui n'existe pas	CORRIGÉ
Fichier	frontend/js/sentry-init.js : ligne 20-21	
Preuve	<pre>var consent = JSON.parse(localStorage.getItem('cookie-consent') 'null'); if (consent && consent.analytics === false) return; — or cookies.js:7 : this.cookieName = 'voldhistoire_cookie_consent' ; cookies.js:296 et 316 : la forme stockée est { preferences: { analytics } }</pre>	
Constat	Double décalage vérifié : mauvaise clé ET mauvaise forme. consent vaut donc toujours null, et la garde ne se déclenche jamais.	
Impact	Sentry se charge et transmet à un sous-traitant américain (IP, URL, contexte navigateur) même quand le visiteur a explicitement refusé les cookies analytiques. Le commentaire du fichier et la politique de confidentialité décrivent un comportement que le code ne produit pas. Effet réel conditionné à la présence d'un DSN en production — non vérifiable depuis ce poste, aucun DSN n'étant injecté en local.	
Correctif	Lire la même clé et la même forme que cookies.js. Mieux : exposer un helper unique VH.consent.get() consommé par les deux fichiers, pour que la forme ne puisse plus diverger.	
Effort	S — moins d'une heure	
Appliqué	frontend/js/cookies.js — accesseur unique window.VH.consent (get / allows / denies) ajouté en fin de fichier ; frontend/js/sentry-init.js:20 le consomme. Un seul fichier connaît désormais le nom de la clé et la forme stockée.	
MAJEUR	RGPD-02 — Le contenu légal de secours affiche des durées de conservation fausses	CORRIGÉ
Fichier	frontend/politique-confidentialite.html : ligne 242 et 252	
Preuve	l.242 : « 2 heures (expiration automatique à chaque connexion) » ; l.252 : « 26 mois maximum » — or fr.json (legal.pc_sec4_body) annonce « Token d'accès JWT : 15 minutes », « Refresh token : 7 jours », « Données analytiques : 14 mois », et backend/middleware/auth.js:14-15 confirme ACCESS_TOKEN_EXPIRY = '15m' / REFRESH_TOKEN_EXPIRY = '7d'	
Constat	Ce HTML statique n'est pas un brouillon : il est affiché tant que i18n.js n'a pas fini son fetch, et définitivement si ce fetch échoue (JS désactivé, réseau, extension bloquante). Les mentions légales ont le même défaut : le fallback ne nomme aucun sous-traitant, là où la version i18n cite Google, Sentry et hCaptcha.	
Impact	Un visiteur sans JavaScript, et tout robot n'exécutant pas JS, lit des durées de conservation fausses et aucune mention des sous-traitants américains. Manquement à l'obligation d'information de l'article 13 du RGPD.	
Correctif	Générer le fallback depuis la même source que fr.json au build, ou rendre ces pages côté serveur comme /details l'est déjà.	
Effort	M — une demi-journée à deux jours	
Appliqué	frontend/politique-confidentialite.html — jetons 2 h → 15 min, ligne « jeton de rafraîchissement : 7 jours » ajoutée, analytics 26 → 14 mois, ligne Sentry 30 jours ajoutée, base légale des analytics corrigée en « consentement ». frontend/mentions-legales.html — Google, Sentry et hCaptcha nommés avec leur pays et les Clauses Contractuelles Types.	

MAJEUR	RGPD-03 — Les drapeaux flagcdn.com sont appelés avant toute décision de consentement	CORRIGÉ
Fichier	frontend/index.html : ligne 15 (repris dans details, favorites, hangar, timeline)	
Preuve	<link rel="preconnect" href="https://flagcdn.com"> ; frontend/js/shared/card.js:32 : src="https://flagcdn.com/\${alpha[aircraft.country_code]}.svg"	
Constat	Contrairement à GTM (defaults « denied » puis chargement conditionnel), rien ne conditionne cet appel tiers. La connexion est même ouverte en preconnect avant l'affichage du bandeau (temporisé à 200 ms).	
Impact	L'adresse IP du visiteur est exposée à un tiers dès le premier rendu, avant tout choix. Aucun cookie n'est déposé par flagcdn d'après le code, donc le risque juridique est moindre qu'un traceur — mais l'appel n'est mentionné nulle part dans la politique, qui se présente comme la liste exhaustive des traceurs.	
Correctif	Auto-héberger les SVG de drapeaux (le projet le fait déjà pour les polices), ou à défaut documenter cet appel dans la politique de confidentialité.	
Effort	S — moins d'une heure	
Appliqué	41 drapeaux auto-hébergés dans frontend/assets/flags/ (PNG 80 px, 15 Ko au total) ; card.js et index.html pointent en local ; preconnect retiré des 5 pages ; flagcdn.com sorti de la CSP (app.js:80). Plus aucune référence au domaine dans le code.	

MINEUR	RGPD-04 — L'inventaire des cookies ne mentionne ni hCaptcha ni Sentry	CORRIGÉ
Fichier	frontend/locales/fr.json : ligne 1218 (legal.pc_sec6_body)	
Preuve	Le tableau liste refreshToken, voldhistoire_cookie_consent, vol-histoire-lang, vh_hangar_view, vh_compare_ids, vh-onboarding-done, _ga, _ga_<ID>, _gid — hCaptcha (chargé sans condition par frontend/js/captcha.js:37) et Sentry n'y figurent pas.	
Constat	Le texte introductif promet la « liste exhaustive des cookies et traceurs déposés ou susceptibles de l'être ». Les deux sous-traitants sont nommés ailleurs (pc_sec5_body) mais absents du tableau technique.	
Impact	Incohérence interne entre la promesse d'exhaustivité et le contenu du tableau.	
Correctif	Ajouter une ligne hCaptcha, ou préciser que le tableau ne couvre que les cookies internes.	
Effort	S — moins d'une heure	
Appliqué	frontend/locales/{fr,en}.json — ligne hCaptcha (Intuition Machines, Inc.) ajoutée au tableau d'inventaire des cookies, dans les deux langues.	

MINEUR	RGPD-05 — Le formulaire d'inscription n'a pas de mention RGPD de proximité	CORRIGÉ
Fichier	frontend/login.html : ligne — (formulaire d'inscription)	
Preuve	Aucune occurrence de « rgpd » ou de mention de finalité près des champs ; contact.html:204 en a une (contact.form_rgpd_notice).	
Constat	Le formulaire qui collecte les données les plus durables (email, mot de passe, nom) est le moins informatif ; celui qui collecte une donnée éphémère (contact) est correctement doté.	
Impact	Information de l'utilisateur incomplète au moment de la collecte.	
Correctif	Ajouter une mention courte (finalité, durée, lien vers la politique) sous le bouton d'inscription, sur le modèle du formulaire de contact.	
Effort	S — moins d'une heure	
Appliqué	frontend/login.html — mention de finalité, durée et lien vers la politique sous le formulaire d'inscription, sur le modèle de celle du formulaire de contact. Clé login.register_rgpd_notice ajoutée en fr et en.	

Vérfié et conforme

- Google Tag Manager correctement conditionné : Consent Mode v2 en « denied » par défaut (gtm.js:15-24), le script distant n'est chargé que par window.__loadGTM() appelé depuis applyConsent() si analytics === true (cookies.js:332-334).

- Refuser est aussi simple qu'accepter : même classe de bouton, un clic, sans passer par la modale (cookie-consent.html:18-25) ; choix granulaire par finalité ; retour sur le consentement depuis le pied de page de toutes les pages et depuis /settings.
- Pages légales substantielles : éditeur nommé, hébergeur OVHcloud avec adresse, base légale par finalité, durées, droits, voie de recours CNIL, sous-traitants nommés avec pays et garanties (Clauses Contractuelles Types).
- Mention RGPD de proximité correcte sous le formulaire de contact (contact.html:204).

10. Qualité du code

Score : 98 → 100/100 — 1 mineur · 1 info · 1 corrigé(s), 1 ouvert(s)

MINEUR	QUAL-01 — Le seuil de couverture de utils.js est en échec permanent	CORRIGÉ
Fichier	frontend/jest.config.json : ligne 20-25	
Preuve	npx jest --coverage : « Coverage for statements (52.43%) does not meet ./js/utils.js threshold (55%) », idem branches 46,84 < 55, fonctions 46,15 < 50, lignes 53,62 < 55. Vérifié sur main avant toute modification de cette session : l'écart préexiste.	
Constat	npm test (sans --coverage) passe, donc l'échec ne bloque personne au quotidien — et c'est le problème.	
Impact	Le garde-fou est en échec constant : il ne peut plus signaler une régression réelle.	
Correctif	Compléter les tests de utils.js, ou abaisser le seuil à la valeur réellement tenue et l'assumer.	
Effort	M — une demi-journée à deux jours	
Appliqué	frontend/js/utils.js — trapFocus exporté, il ne l'était pas, d'où son absence de tests ; 16 tests ajoutés couvrant safeSetHTML, trapFocus et setNumberPopIn. Couverture de utils.js : 52,43 % → 91,46 % des instructions.	

INFO	QUAL-02 — Convention de guillemets non tenue dans quelques fichiers	OUVERT
Fichier	frontend/js/login.js : ligne 1 et suivantes	
Preuve	≈24 occurrences de guillemets doubles dans login.js ; addEventListener("DOMContentLoaded", ...) en doubles dans 5 fichiers (favorites.js:3, login.js:1, script.js:2, settings.js:1, timeline.js:6) ; 12 occurrences dans backend/validators.js:168-193 et app.js:55,147.	
Constat	La règle du projet est le guillemet simple en JS. ESLint ne l'applique pas (aucune règle quotes configurée).	
Impact	Cosmétique.	
Correctif	Ajouter la règle quotes à ESLint et laisser --fix faire la passe.	
Effort	S — moins d'une heure	

Vérifié et conforme

- ESLint : 0 problème sur backend/, frontend/js/ et scripts/. Aucun TODO, FIXME ou HACK dans tout le dépôt. Aucun console.log résiduel hors du logger et d'un script CLI de migration.
- 551 tests backend, 146 tests frontend, 121 scénarios E2E Playwright — tous verts au moment de l'audit, hors un échec E2E dû à un schéma de base locale obsolète.
- Intégration continue GitHub Actions avec PostgreSQL 16 en service, secrets injectés par l'environnement du job.

11. Mobile & PWA

Score : 98 → 100/100 — 1 mineur · 1 corrigé(s), 0 ouvert(s)

MINEUR	PWA-01 — Le manifeste PWA annonce 107 fiches au lieu de 383	CORRIGÉ
Fichier	frontend/manifest.webmanifest : ligne 5	
Preuve	"description": "Encyclopédie de l'aviation militaire : 107 fiches détaillées, chronologie cinématographique, hangar interactif."	
Constat	Le catalogue compte 383 fiches depuis la v4.7.0. Cette description s'affiche au moment de l'installation de l'application.	
Impact	Information fausse à l'instant précis où l'utilisateur décide d'installer.	
Correctif	Corriger la description, et envisager de retirer le chiffre pour éviter la péremption.	
Effort	S — moins d'une heure	
Appliqué	frontend/manifest.webmanifest:5 — le chiffre est retiré de la description plutôt que corrigé, pour qu'il ne périclite plus à chaque lot de fiches.	

Vérifié et conforme

- Manifeste complet (id, scope, display, orientation, thème, catégories, icônes 192 et 512 présentes et maskable) ; service worker versionné avec purge des anciens caches, network-first sur l'API et stale-while-revalidate sur les assets.

12. Contenu & éditorial

Score : 98 → 100/100 — 1 mineur · 1 info · 2 corrigé(s), 0 ouvert(s)

MINEUR	CONT-01 — Espaces insécables appliqués dans les pages légales mais pas ailleurs	CORRIGÉ
Fichier	frontend/locales/fr.json : ligne 228 et 78 autres occurrences	
Preuve	79 occurrences d'espace normal avant « : », « ; », « ! » ou « ? » dans les textes courants (accueil, chronologie, connexion, contact, favoris), alors que les pages légales emploient correctement (ex. politique-confidentialite.html:339 : « n° 2020-091 : »).	
Constat	Exigence typographique française appliquée à une partie du contenu seulement.	
Impact	Rupture de ligne possible avant une ponctuation double en fin de ligne. Rendu correct dans la grande majorité des cas.	
Correctif	Uniformiser dans un sens ou dans l'autre, idéalement l'espace insécable partout.	
Effort	M — une demi-journée à deux jours	
Appliqué	frontend/locales/fr.json — 146 espaces insécables (U+00A0) posés avant : ; ! et ?. Le caractère et non l'entité ; i18n.js affecte textContent pour les clés simples, où une entité s'afficherait littéralement. L'anglais est inchangé, la parité des 1225 clés est préservée.	

INFO	CONT-02 — Documentation d'architecture décalée des versions installées	CORRIGÉ
Fichier	CLAUDE.md : ligne 8	
Preuve	« Express 4.21 [...] PostgreSQL via pg 8.13 » — npm ls : express@5.2.1, pg@8.20.0. Express 5 change le routage et la gestion des erreurs asynchrones.	
Constat	La documentation de référence du projet annonce une version majeure de retard sur son framework serveur.	
Impact	Risque de contresens pour un nouvel arrivant ou lors d'une future migration.	
Correctif	Mettre à jour la section Stack de CLAUDE.md et du README.	
Effort	S — moins d'une heure	
Appliqué	CLAUDE.md et README.md — Express 4.21 → 5.2, pg 8.13 → 8.20, Nodemailer 10 mentionné, avec un renvoi aux différences de routage d'Express 5.	

Vérifié et conforme

- Parité totale des 1222 clés de traduction FR/EN, aucune chaîne longue laissée en français côté anglais. Copyright 2026 à jour sur toutes les pages. Aucune faute d'orthographe relevée dans l'échantillon lu.

Plan d'action restant

Les 43 constats corrigés ne figurent plus ici : leur correctif est décrit dans la section du domaine correspondant, ligne « Appliqué ». Ne restent que les 9 constats ouverts, plus celui écarté sur décision.

■ À traiter en priorité

Le seul constat majeur encore ouvert.

ID	Action	Fichier	Sév.
PERF-08	Investiguer séparément. Deux pistes à mesurer : l'animation <code>.gradient-text</code> de <code>style-hero-split.css</code> , dont le <code>fill-mode</code> <code>both</code> et le délai de 0,7 s laissent le texte transparent au premier rendu ; et le remplacement de texte opéré par <code>i18n.js</code> après chargement des locales, qui redéclenche une candidature LCP.	frontend/index.html:105-112	Majeur

■ Quand l'occasion se présente

Constats mineurs : correctifs courts, sans urgence.

ID	Action	Fichier	Sév.
SEC-04	Ajouter <code>{ algorithms: ['HS256'] }</code> aux trois appels.	backend/middleware/auth.js:170 (+ routes/auth.js:192 et 249)	Mineur

■ Observations

Aucune action requise — consignées pour mémoire.

ID	Action	Fichier	Sév.
SEC-06	Ajouter une validation de longueur (100 caractères).	backend/routes/contact.js:14 et 27	Info
PERF-06	Optionnel : inliner le CSS critique du hero et charger le reste en asynchrone.	frontend/index.html:42-43	Info
PERF-07	Aucune action requise. À surveiller si le catalogue double : envisager un stockage d'objets plutôt que le dépôt Git.	frontend/assets/airplanes/:—	Info
SEO-03	Raccourcir de quelques mots.	frontend/timeline.html:—	Info
CSS-05	Aligner la documentation sur la réalité, ou converger vers l'échelle de tokens lors des prochaines retouches.	frontend/css/:—	Info
ARCH-03	Découper <code>shared-base.css</code> par domaine au prochain passage sur le CSS.	frontend/css/shared-base.css:—	Info
QUAL-02	Ajouter la règle <code>quotes</code> à ESLint et laisser <code>--fix</code> faire la passe.	frontend/js/login.js:1 et suivantes	Info

■ Écarté sur décision

ARCH-02 — 17 fichiers SVG de logo ne sont référencés nulle part

Écarté à la demande : ces 17 fichiers sont un stock de déclinaisons de charte conservé pour un usage futur, pas un oubli.

Annexe A — Points conformes vérifiés

Un audit qui ne liste que les défauts ment par omission : il laisse croire que le reste n'a pas été regardé. Les 32 points suivants ont été contrôlés et se sont révélés corrects.

7. Sécurité

- Requêtes SQL systématiquement paramétrées — aucune concaténation de valeur utilisateur trouvée (routes/auth.js:43,111 ; routes/airplanes.js:505-543 ; routes/users.js:37-46).
- Mots de passe hachés bcrypt coût 12 (routes/auth.js:47), comparaison contre un hash factice si l'utilisateur n'existe pas (auth.js:118-120) pour éviter l'énumération par temps de réponse.
- Verrouillage de compte après 10 échecs pendant 15 min (routes/auth.js:97-98,135-151), réponse identique dans tous les cas d'échec.
- Jeton d'accès de 15 min + refresh token en base, rotation atomique en transaction et détection de rejeu révoquant toutes les sessions (middleware/auth.js:89-106 ; routes/auth.js:211-233).
- Cookie de refresh httpOnly + secure en production + sameSite strict + path limité à /api (middleware/auth.js:143-149) ; le jeton d'accès n'est jamais en localStorage (js/auth.js:5,19).
- Contrôle de propriété sur les ressources utilisateur (isOwnerOrAdmin, middleware/auth.js:192-203) et favoris toujours filtrés par req.user.id — aucun IDOR trouvé.
- En-têtes de sécurité complets, vérifiés sur la réponse HTTP réelle : HSTS preload, X-Frame-Options DENY, X-Content-Type-Options, Referrer-Policy, Permissions-Policy, COOP, CORP, X-Powered-By retiré.
- CSP sans 'unsafe-inline' : nonce sur les styles, style-src-attr 'none', object-src 'none', frame-ancestors 'none', base-uri et form-action 'self'.
- Limitation de débit différenciée par route sensible avec Redis et repli mémoire ; hCaptcha sur inscription, mot de passe oublié et contact ; corps JSON plafonné à 100 Ko.
- Aucun secret en dur : JWT_SECRET et REFRESH_SECRET obligatoires et vérifiés ≥ 32 caractères au démarrage (server.js:5-18) ; *.env gitignoré, seul .env.example versionné.

6. Accessibilité

- axe-core 4.13.0 (WCAG 2.0/2.1/2.2 A + AA) sur 11 pages : une seule violation, le contraste de settings (A11Y-02). Accueil, hangar, chronologie, connexion, contact, favoris, pages légales et 404 sortent à zéro violation.
- Lighthouse accessibilité : 100/100 sur l'accueil.
- Tous les du HTML source ont un alt ; aucun bouton ou lien à icône seule sans aria-label.
- Formulaire : chaque champ a un <label for> correspondant ou un label englobant, sur contact, login, settings, forgot-password et reset-password.
- Onglets ARIA complets (tablist/tab/tabpanel, aria-selected, tabindex roving, inert sur le panneau inactif) sur login.html:159-228 et settings.html:97-230 ; modales avec role=dialog + aria-modal + aria-labelledby ; navigation clavier flèches et Échap sur les menus déroulants (js/nav.js:149-185).
- Lien d'évitement et <main id="main-content"> présents et corrects sur 10 des 12 pages applicatives complètes.

9. Conformité RGPD

- Google Tag Manager correctement conditionné : Consent Mode v2 en « denied » par défaut (gtm.js:15-24), le script distant n'est chargé que par window.__loadGTM() appelé depuis applyConsent() si analytics === true (cookies.js:332-334).
- Refuser est aussi simple qu'accepter : même classe de bouton, un clic, sans passer par la modale (cookie-consent.html:18-25) ; choix granulaire par finalité ; retour sur le consentement depuis le pied de page de

toutes les pages et depuis /settings.

- Pages légales substantielles : éditeur nommé, hébergeur OVHcloud avec adresse, base légale par finalité, durées, droits, voie de recours CNIL, sous-traitants nommés avec pays et garanties (Clauses Contractuelles Types).
- Mention RGPD de proximité correcte sous le formulaire de contact (contact.html:204).

8. SEO technique

- Lighthouse SEO : 100/100. Les 18 pages ont un <title> unique et non vide ; 14 ont description + canonical + Open Graph ; les 4 pages transactionnelles portent noindex, nofollow, comme login, settings, favoris et 404.
- Rendu serveur dédié aux fiches (details-ssr.js) : title, description, canonical, OG, Twitter et JSON-LD hydratés par appareil, avec redirection 301 des anciennes URL ?id= vers l'URL canonique en slug.
- Sitemap dynamique couvrant les pages publiques et les 383 fiches, avec cache Redis 24 h et repli statique si la base est indisponible ; robots.txt cohérent et déclarant le sitemap.

2. HTML & sémantique

- html-validate : 0 erreur sur les 18 pages (configuration html-validate:recommended).
- Exactement un <h1> par page dans le HTML source ; lang, charset et viewport présents partout, sans user-scalable=no.

10. Qualité du code

- ESLint : 0 problème sur backend/, frontend/js/ et scripts/. Aucun TODO, FIXME ou HACK dans tout le dépôt. Aucun console.log résiduel hors du logger et d'un script CLI de migration.
- 551 tests backend, 146 tests frontend, 121 scénarios E2E Playwright — tous verts au moment de l'audit, hors un échec E2E dû à un schéma de base locale obsolète.
- Intégration continue GitHub Actions avec PostgreSQL 16 en service, secrets injectés par l'environnement du job.

4. JavaScript

- Aucun eval, new Function, document.write, insertAdjacentHTML ni outerHTML dans les sources. Les 113 usages d'innerHTML passent par escapeHtml ou DOMPurify (utils.js:33-53).

11. Mobile & PWA

- Manifeste complet (id, scope, display, orientation, thème, catégories, icônes 192 et 512 présentes et maskable) ; service worker versionné avec purge des anciens caches, network-first sur l'API et stale-while-revalidate sur les assets.

5. Performance

- CLS 0,005 et TBT 90 ms mesurés par Lighthouse ; polices auto-hébergées en woff2 avec font-display: swap et preload des deux plus critiques ; aucun contenu mixte http:// dans les sources.

12. Contenu & éditorial

- Parité totale des 1222 clés de traduction FR/EN, aucune chaîne longue laissée en français côté anglais. Copyright 2026 à jour sur toutes les pages. Aucune faute d'orthographe relevée dans l'échantillon lu.

Annexe B — Limites de cet audit

Ce qui suit n'a pas pu être vérifié dans les conditions de l'audit. Ces points sont signalés comme non testés plutôt que supposés conformes.

Sujet	Raison
Comportement réel de Sentry en production	Aucun DSN n'est injecté dans le HTML servi en local : impossible de confirmer par l'observation que Sentry se charge malgré un refus (RGPD-01). Le défaut est établi par lecture du code, pas par exécution.
Contournement effectif de la limitation de débit via ip-address	La vulnérabilité est réelle dans la dépendance, mais aucun test n'a été construit pour prouver qu'une IP forgée contourne la clé de limitation dans ce projet (JS-01).
Contraste réel de l'indicateur de focus	Le ratio de 1,9:1 (A11Y-03) est calculé par composition alpha sur la couleur de fond documentée, pas mesuré à l'écran. axe ne teste pas le contraste des indicateurs de focus.
Lighthouse sur les autres pages	Une seule exécution Lighthouse, sur l'accueil. Les fiches, le hangar et la chronologie n'ont pas été mesurés : leurs scores peuvent différer.
Exception d'espacement des cibles tactiles	Pour A11Y-12, l'espacement entre cibles voisines n'a pas été mesuré : la conformité formelle de ces liens n'est donc ni établie ni infirmée.
Audit sur base de production	Toutes les mesures viennent d'une base locale partielle (111 fiches contre 383 en production). Les temps de réponse SQL et les volumes de pagination peuvent différer.
Analyse de duplication automatisée (jscpd)	Non exécutée : la duplication a été recherchée manuellement par grep sur les motifs signalés.

Annexe C — Méthodologie

Outils exécutés

Outil	Version	Portée	Résultat brut
axe-core	4.13.0	11 pages, via Playwright (CDP)	1 violation (color-contrast, 6 nœuds)
Lighthouse	12.8.2	Accueil, émulation mobile	Perf 86 · A11y 100 · BP 96 · SEO 100
html-validate	9.x	18 pages HTML	0 erreur
ESLint	9.39.4	backend, frontend/js, scripts	0 problème
npm audit	npm 10	backend, racine, frontend, e2e	10 vulnérabilités en production
Jest	30.4.2	backend + frontend	551 + 146 tests au vert
Playwright	1.x	19 specs E2E	120 réussis, 1 échec (schéma local)
Playwright (mesures)	1.x	Cibles tactiles, 2 résolutions	5 classes de liens < 24 px

Vérification après correctifs

Chaque correctif a été vérifié par l'outil qui avait servi à établir le constat, sur un serveur local relancé. Deux points ont demandé une contre-mesure particulière : le choix de sortir icons.js du bundle commun a été tranché par un A/B Lighthouse (deux exécutions par variante, dos à dos), et l'apparente régression du FCP a été écartée en remesurant l'état d'origine remis en place à l'identique — il varie lui-même de 1210 à 1662 ms d'une exécution à l'autre.

Commandes principales

```
npx html-validate "frontend/*.html"
npm run lint (eslint backend/ frontend/js/ scripts/)
cd backend && npm audit --omit=dev --json
cd backend && npx jest | cd frontend && npx jest --coverage
cd e2e && npx playwright test
npx lighthouse http://localhost:3000/ --only-categories=performance,accessibility,best-practices,seo
node axe-run.js (axe-core injecté via page.evaluate sur 11 pages)
node targets.is (getBoundingClientRect sur tous les éléments interactifs, 1440 px et 390 px)
curl -s -D - -o /dev/null http://localhost:3000/ (en-têtes de sécurité réels)
grep -rEn "(api| -)?key|secret|password|token)s*[:|=]" --include="*.js" (recherche de secrets)
cd backend && npm audit fix puis npm install nodemailer@^10 (JS-01)
node axe-run.js (re-execute apres correctifs : 0 violation sur 11 pages)
```

Notation

Score d'un domaine = $100 - (15 \times \text{critique} + 6 \times \text{majeur} + 2 \times \text{mineur})$, plancher à 0. Les constats informatifs ne retirent aucun point : ce sont des observations, pas des défauts. Le barème reste doux sur les mineurs à dessein — un domaine audité en profondeur en remonte mécaniquement plus qu'un domaine survolé, et il serait absurde de le pénaliser pour cela.

Score global = moyenne pondérée des douze domaines : sécurité $\times 2$; performance, accessibilité et conformité RGPD $\times 1,5$; contenu éditorial $\times 0,5$; les autres $\times 1$.

Conditions

Audit mené le 8 septembre 2026 sur le dépôt C:\Users\titou\Documents\vol_histoire, version v4.9.0, branche main. Serveur local Node.js sous NODE_ENV=test, PostgreSQL local contenant 111 fiches (contre 383 en

production) — les mesures de volume et de temps de réponse SQL ne sont donc pas transposables telles quelles. Aucun fichier du projet n'a été modifié pendant l'audit ; les deux livrables sont écrits dans audit/.